Recommandations à la direction

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans `constat/etat-implementation.md`.*

> *Ticket : WOR-72 · Responsable : Cédric · Version 1.0 du 22/10/2026*
>
> *Synthèse des autres documents de `cible/`. Les preuves viennent des répétitions du 22/10 (`rto-rpo.md` §6) ; celles qui restent à produire sont marquées à mesurer.*

Synthèse pour la direction

1. **Un arrêt de paiement coûte peu pendant 5 minutes, puis le coût explose.** Une heure d'arrêt en pointe coûte environ 700 k€, essentiellement en pénalités contractuelles, et déclenche probablement une notification à l'ACPR au titre de DORA.
2. **La reprise automatique est donc l'investissement prioritaire.** Aux répétitions, le démonstrateur a rétabli le service en ≈ 40 s après un déni de service, vérifié par une transaction réelle et sans intervention humaine, contre 30 minutes ou plus pour une reprise manuelle.
3. **Elle ne suffit pas pour une attaque sur l'intégrité des données.** Une injection impose de préserver les preuves, de vérifier les données et de notifier, même si le service revient vite. En production, l'automate ne doit pas décider seul dans ce cas ; le démonstrateur le fait, pour la démonstration.
4. **Le démonstrateur repose sur un seul serveur.** C'est acceptable pour prouver le principe, pas pour la production : un deuxième site et des sauvegardes hors site sont la première dépense à prévoir.
5. **Nous demandons trois décisions** à la direction (dernière section).

0. Ce que les essais ont prouvé, et ce qui manque

Au 22/10, la chaîne détection → remédiation → vérification est codée et mesurée sur l'attaque A : reprise en ≈ 40 s, sans transaction perdue ni intervention humaine. Il manque la sauvegarde de la base, et dans le socle l'API garde ses données en mémoire : un redémarrage ou une restauration perd les transactions. Les écarts restants sont dans `constat/etat-implementation.md` §4.

1. Les arbitrages que nous avons faits

Arbitrage	Ce que nous avons choisi	Ce que nous avons écarté	Pourquoi	Ce que ça coûte
Quoi protéger d'abord	La chaîne de paiement : API, base, authentification, WAF	Protéger tous les services au même niveau	Ce sont eux qui portent le revenu et l'engagement envers les 200 partenaires	L'assistant RAG et la consultation passent après
Automatique ou humain	Pour la démo : tout automatique, un humain n'intervient qu'en cas d'échec (2 tentatives)	Faire valider les restaurations par une personne	Montrer une reprise sans intervention dans le temps imparti	Une alerte à tort peut déclencher une restauration ; en production, nous recommandons l'inverse (REC-2, REC-3)

Arbitrage	Ce que nous avons choisi	Ce que nous avons écarté	Pourquoi	Ce que ça coûte
Vitesse ou preuves	Restaurer au plus vite ; preuves exportées à la main (`scripts/export-logs.sh`)	Bloquer la reprise tant que la copie n'est pas faite	Garder le temps de reprise court	Si l'export est oublié, une remise à l'état sain efface les preuves
Scénario principal de la démo	Déni de service (risque R1) ; injection en second scénario	Une seule attaque	R1 est le risque le plus élevé ; le second scénario montre que la réponse dépend du type d'incident	Deux chaînes de remédiation à construire et tester
Hébergement	Tout sur un hôte, sans dépendance à un cloud	Services managés	Imposé par le cadre du projet ; évite aussi le risque lié à un prestataire	Point de défaillance unique, assumé et documenté
Restauration après injection	Retour à l'état de départ : recréation du conteneur de l'API	Snapshot et rejeu des transactions légitimes	Simple et rapide à démontrer	**Toutes les transactions sont perdues** : RPO = 0 non tenu (REC-6). Et une tentative d'injection bloquée par le WAF déclenche quand même la restauration
Référentiels	DORA, EBIOS RM ; NIS2 en grille de lecture	PCI DSS	Aucune donnée de carte manipulée	—

2. Recommandations

Chaque recommandation repose sur un élément **vérifiable**, issu de nos essais ou de nos documents.

Priorité 1 — à décider maintenant

#	Recommandation	Élément vérifiable	Effort
REC-1	**Généraliser la reprise automatique** aux incidents de disponibilité sur toute la chaîne de paiement	Reprise totale mesurée : ≈ 40 s sur l'attaque A ; interventions humaines pendant les répétitions : 0 (WOR-78)	Moyen
REC-2	**Garder un humain dans la boucle pour les incidents d'intégrité** : blocage automatique, mais restauration et notification validées par une personne. Le démonstrateur restaure automatiquement : c'est un choix de démo, pas une cible de production	Fiche S2 du PCA ; délai entre l'alerte et la décision humaine, à mesurer en exercice	Faible
REC-3	**Exiger deux signaux concordants** avant toute action destructrice (le démonstrateur agit sur une seule alerte ML)	Faux positifs du modèle : environ une fausse alerte de trafic toutes les 7 h ; le 21/10, deux fausses alertes d'injection ont chacune déclenché une restauration à tort (`ml/training/README.md`)	Faible
REC-4	**Encadrer le moteur de remédiation** comme un bien critique : périmètre d'actions limité, appels authentifiés, journalisation	Revue des droits du moteur (WOR-64) ; essai d'appel depuis un composant non autorisé, qui doit être refusé	Moyen

Priorité 2 — dans les 6 mois

#	Recommandation	Élément vérifiable	Effort
REC-5	**Sauvegardes hors site et immuables**, avec restauration testée chaque trimestre	Temps de restauration mesuré ; nombre de transactions perdues à la restauration	Moyen
REC-6	**Restauration de la base à un instant précis** (archivage continu des journaux de la base), pour tenir zéro transaction perdue après une injection	Essai d'injection suivi d'une restauration, sans transaction légitime perdue	Moyen
REC-7	**Procédure de notification DORA** : classification, brouillon préparé à partir des journaux, validation, envoi à l'ACPR	Exercice de notification chronométré face aux délais réglementaires	Faible
REC-8	**Programme annuel de tests de résilience** couvrant tous les risques retenus dans l'EBIOS, pas seulement le scénario de démo	Taux de couverture des risques R1 à R8 par au moins un test	Moyen

Priorité 3 — dans les 12 mois

#	Recommandation	Élément vérifiable	Effort
REC-9	**Deuxième site** (ou deuxième zone de disponibilité), avec bascule testée	Durée de bascule mesurée	Élevé
REC-10	**Protection anti-déni de service en amont** du WAF, pour les attaques distribuées	Essai de charge distribuée	Moyen, souvent sous forme de service
REC-11	**Gestion des prestataires TIC selon DORA** : registre, clauses contractuelles, plans de sortie	Registre à jour, contrats revus	Moyen

Ordre de grandeur pour arbitrer : un seul incident de 30 minutes à 2 heures en pointe coûte environ 700 k€ (`services-critiques.md`). Les priorités 1 et 2 visent à ce qu'il ne se produise pas ; la priorité 3 protège contre la perte complète du site.

3. Ce que nous ferions autrement en contexte industriel

Dans le démonstrateur	En production
Un seul hôte, sauvegardes locales	Deux sites, sauvegardes hors site et immuables
Un modèle ML entraîné sur 7,3 h de trafic de la plateforme	Plusieurs semaines de données réelles, réentraînement régulier, suivi de la dérive du modèle
Deux scénarios d'attaque, joués par l'équipe	Programme de tests annuel, tests d'intrusion par des testeurs indépendants (TLPT si l'entité est désignée)
Notification décrite sur papier	Procédure exercée, astreinte conformité, modèles de rapports ACPR
Aucun contrat avec les prestataires TIC	Registre d'information, clauses DORA, plans de sortie (REC-11)
Données fictives, sauf les visages des membres de l'équipe enrôlés pour la double authentification (consentement écrit, effacement après la démo ; cadre : `docs/governance/rgpd-biometrie.md`)	Analyse d'impact sur la protection des données (AIPD) avant de traiter des données réelles, obligatoire pour la biométrie (RGPD art. 9 et 35) ; double authentification proposée aussi aux clients ; détection du vivant pour la reconnaissance faciale
Rôles fictifs (directeur de crise, RSSI, DPO)	Rôles nommés, suppléants, exercices de crise deux fois par an

Dans le démonstrateur	En production
Hypothèses financières fictives	Analyse d'impact sur l'activité menée avec les métiers et la finance
Gouvernance portée par l'équipe projet	Cadre de risque TIC approuvé par l'organe de direction, comme l'exige DORA (art. 5)

4. Limites de cette analyse

- Les chiffres financiers sont **fictifs**. Ils donnent des ordres de grandeur, pas un budget.
- Les seuils DORA et les délais de notification sont repris de notre lecture des textes, à confirmer par un juriste.
- Les temps de reprise viennent de répétitions sur le démonstrateur, pas d'un incident réel. L'attaque B n'a pas été chronométrée.

5. Décisions demandées à la direction

1. **Valider le principe d'une reprise automatique** pour les incidents de disponibilité, avec validation humaine pour les incidents d'intégrité (REC-1, REC-2).
2. **Accepter le risque résiduel de l'hôte unique** pour la phase pilote, et **inscrire au budget** les sauvegardes hors site (REC-5) puis le deuxième site (REC-9).
3. **Désigner les responsables** des rôles du PCA (directeur de crise, conformité, astreinte) et planifier un premier exercice de crise.